

AIT: Adversarial Integration Testing

for SaaS APIs via Differential Fuzzing and Taint-Seeded Data
Tracking

Product Name	Adversarial Integration Tester (AIT)
Document Status	Final / V1.0
Project Code	BIC685 — Major Project Phase 1
Authors	Adithya M N Alaap V Prajwal S Nikhil Gowda T S
Guide	Apeksha Gowda, Asst. Professor, Dept. of CSE (ICB), BIT
Institution	Bangalore Institute of Technology, Bengaluru – 560004
Tech Stack	Python 3.11+ FastAPI Pydantic v2 asyncio/httpx
Detection Methods	Differential Fuzzing Taint-Seeded Markers Dual-Phase Execution
Threat Coverage	C1: Over-scope C2: Field Harvesting C3: State-Dependent Evasion
Date	2025

Submitted to:

Department of CSE (IoT & Cybersecurity Including Blockchain Technology)
Bangalore Institute of Technology, Bengaluru – 560004

Contents

Abstract	3
1 Introduction	4
1.1 Background and Motivation	4
1.2 Problem Statement	4
1.3 Scope and Claims	5
1.4 Threat Model	5
1.5 Research Contributions	6
1.6 Novelty and Positioning	7
2 Literature Survey	8
2.1 OAuth 2.0 Security and Permission Models	8
2.2 API Fuzzing and Differential Testing	8
2.3 Taint Analysis	9
2.4 SaaS Security Auditing and Zero-Trust	9
2.5 Tool Capability Taxonomy	9
2.6 Summary of Research Gaps	10
3 System Design	12
3.1 High-Level Architecture	12
3.2 Coordinator API	12
3.3 Mock SaaS Service	12
3.4 Live SaaS Runner	13
3.5 Analysis Engine and Data Model	13
3.6 CI/CD Deployment Sketch	13
4 Methodology	14
4.1 Dual-Phase Execution Model	14
4.2 Taint-Seeded Data Tracking	14
4.3 Detection Mechanisms	15
4.4 Informal Detection Guarantees	16
4.5 Risk Scoring Model	16

5	Hardware and Software Requirements	17
5.1	Hardware Requirements	17
5.2	Software Requirements	17
5.2.1	Core Runtime	18
5.2.2	Development and Testing Tools	18
5.2.3	Network and API Access	19
5.2.4	Optional Production Dependencies	19
5.2.5	Installation and Setup	19
5.2.6	Implementation: Core Detection Logic	20
5.2.7	Functional Requirements	23
6	Experimental Evaluation	25
6.1	Evaluation Design and Scope	25
6.2	Mock Environment: Test Scenarios	25
6.3	Mock Environment: Detection Results	25
6.4	Platform-Inspired Mock Suite	26
6.5	Live SaaS Evaluation	26
6.6	Live GitHub REST Smoke Probe	27
6.7	Robustness and Noise	27
6.8	Tool Capability Comparison	28
6.9	Log-Based Replay: Real-Data Signal	28
6.10	Risk Score Sensitivity Analysis	28
6.11	Analysis Engine Micro-Benchmark	29
7	False Negative Analysis	30
7.1	FN1 — Out-of-Band Exfiltration	30
7.2	FN2 — Shared Token Misuse	30
7.3	FN3 — Time-Delayed or Trigger-Based Activation	31
7.4	FN4 — Response-Field Aliasing	31
8	Limitations and Future Scope	32
8.1	Current Limitations	32
8.2	Future Scope	32
9	Conclusion	34

Abstract

Third-party SaaS integrations hold OAuth tokens that may exceed declared needs, yet few tools check whether runtime traffic matches an explicit integration policy. This report presents the Adversarial Integration Tester (AIT), an open-source framework combining dual-phase API stimulation with run-attributed marker checks to surface undeclared endpoints, sensitive fields, and baseline/mutated divergence — classes that static scope audits and server-focused fuzzers do not address.

AIT is explicitly a proof-of-concept: a three-scenario CRM mock suite yields precision and recall of 1.0 on injected violations; a seven-scenario platform-inspired suite reports 100% precision (5 TP, 0 FP) on declared labels; version-controlled YAML and a deterministic in-process runner enable reproducible tables. A live SaaS evaluation pipeline validates the same detection logic on real provider APIs: a GitHub sandbox probe detects a policy violation (risk score 30, High severity) when private repository listing succeeds beyond the declared scope, while a Notion read-path probe correctly produces no findings on a compliant integration — together demonstrating positive and negative control behaviour on live REST traffic.

Replayed public incident sketches align AIT categories with independently reported violations. Risk-score perturbation $\pm 30\%$ leaves critical-band classification stable; full production generalisation remains future work.

Index Terms — SaaS security, API fuzzing, taint analysis, OAuth, adversarial testing, behavioral divergence, third-party integrations, zero-trust, DevSecOps.

1 Introduction

1.1 Background and Motivation

The SaaS model dominates enterprise software delivery. Platforms such as Salesforce, Slack, Google Workspace, and GitHub expose REST and GraphQL APIs whose value is realised through third-party integrations — automation tools, native add-ons, and custom connectors that move data across organisational boundaries. The Cloud Security Alliance reports that the average enterprise SaaS environment maintains over 100 active third-party integrations, each holding delegated access tokens that persist beyond initial authorisation [1].

OAuth 2.0 (RFC 6749) underpins nearly all SaaS integration authentication, granting time-limited, scope-bounded access tokens. However, OAuth scopes are coarse categories that map imprecisely to individual endpoints. Google’s single `https://mail.google.com/` scope grants unrestricted access to the entire Gmail API surface; Slack’s `channels:history` scope exposes all messages across all public channels; GitHub’s `repo` scope grants read and write access to all private repositories. In no case does the scope name communicate the breadth of data exposure it enables.

Real-world incidents confirm integrations are a primary attack surface. SolarWinds (2020), Okta (2022), and CircleCI (2023) each involved trusted third-party tooling or tokens operating beyond intended scope [2, 3, 4]. Aliyu et al. confirm that over-privileged OAuth grants are a persistent and understudied enterprise attack vector [6].

1.2 Problem Statement

No systematic mechanism exists to verify that a SaaS integration’s runtime API behaviour conforms to its declared permission scope. Static approaches (scope auditing tools, permission dashboards) cannot observe runtime behaviour. Dynamic approaches (general-purpose API fuzzers) test the server for vulnerabilities but do not model the integration as a potentially malicious client. Neither can detect:

- **Hidden endpoint access** — calls to endpoints outside the declared policy.
- **Sensitive field access** — retrieval of confidential fields on otherwise-accessible endpoints.
- **Behavioural divergence** — access patterns that change with runtime state, concealing unauthorised access from static audits.

1.3 Scope and Claims

This report makes the following bounded claims. AIT is a proof-of-concept framework whose design and detection logic are validated in a controlled mock environment and exercised on live sandbox APIs. Results within the mock environment are exact by construction; live results reflect behaviour of real vendor APIs under the supplied token and declared policy. The contribution is the framework design, threat model, and methodology; empirical scale validation is future work.

1.4 Threat Model

The adversary is a malicious or misconfigured SaaS integration legitimately granted OAuth access by a user or administrator. Three capability classes are modelled:

- **C1 — Over-scope access:** Calling endpoints not in the declared policy, enabled by over-provisioned scopes.
- **C2 — Sensitive field harvesting:** Reading response fields classified as confidential (PII, billing data) from accessible endpoints.
- **C3 — State-dependent evasion:** Behaving benignly under normal observation but activating unauthorised access under specific runtime conditions (feature flags, plan-tier signals, time-based triggers).

The security goal is to detect all three capability classes through black-box observation only — no code instrumentation of the integration under test. Out of scope: denial-of-service, credential theft from the SaaS platform, and OAuth server implementation vulnerabilities.

Known detection boundaries: AIT cannot detect violations that occur entirely outside the instrumented API surface, including out-of-band exfiltration (e.g., via webhooks), side-channel data leakage, and access by a different OAuth token not issued to the IUT. These are analysed as false negative cases in Chapter 7 (Figure 7.1).

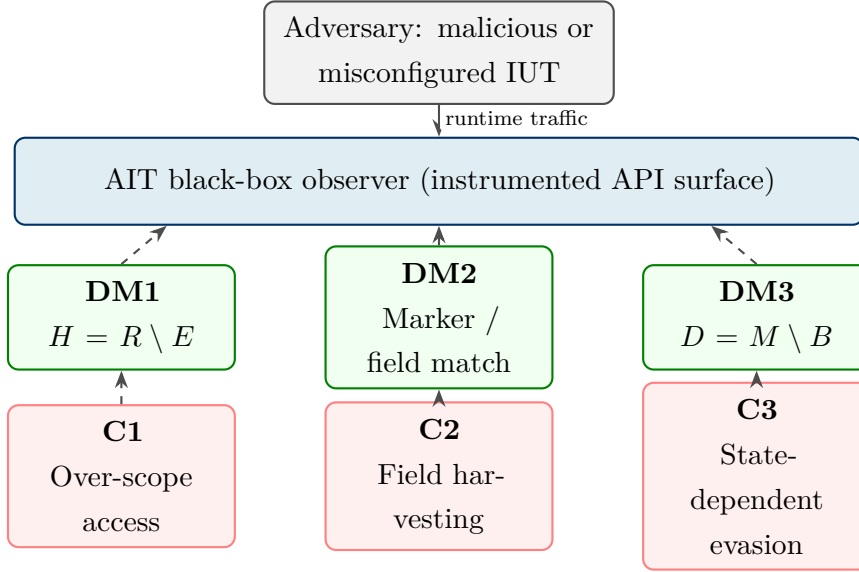


Figure 1.1. Threat capabilities (C1–C3) mapped to AIT detection mechanisms (DM1–DM3). DM4 (live policy violations) extends DM1-style checks to real provider APIs.

1.5 Research Contributions

- An integration-centric adversarial testing methodology treating the integration as the test subject, combining differential API fuzzing with taint-seeded data tracking.
- The AIT framework: a modular, open-source Coordinator API, Mock SaaS service, and Analysis Engine, detecting three violation categories with structured risk scoring.
- A dual-phase execution model (baseline / mutated) that surfaces state-dependent evasion (C3) invisible to static analysis and single-phase testing.
- An instrumentation-free taint-injection mechanism operating at the data layer, enabling precise run-attributed detection of sensitive field access.
- A live SaaS evaluation pipeline (`ait/live_runner.py`) validated on GitHub and Notion sandbox accounts.
- A log-based replay experiment applying AIT’s detection logic to real SaaS incident traces.
- A false negative analysis characterising four evasion scenarios that defeat the current detection model.
- A risk scoring sensitivity analysis demonstrating stable Critical-band classification across $\pm 30\%$ weight perturbation.

- A multi-ecosystem mock evaluation harness with seven YAML-defined scenarios spanning Slack-, GitHub-, Gmail-, Notion-, and Trello-style REST idioms, with automated aggregation for reproducible tabular results.
- A read-only GitHub REST smoke probe, robustness-style mock variants, an FN4 negative demo for aliased secret fields, and a micro-benchmark of Analysis Engine latency versus synthetic log width.

1.6 Novelty and Positioning

Unlike prior API-testing and OAuth-auditing tools, AIT introduces an explicit verification axis: integration-policy conformance — do runtime calls and returned fields stay within an operational policy artifact (`TargetConfig`)? This axis is orthogonal to server-side vulnerability discovery and to static OAuth auditing without behavioural reconciliation; AIT is a policy-reconciliation framework deployed alongside — not as a replacement for — existing fuzzers and permission tools.

2 Literature Survey

2.1 OAuth 2.0 Security and Permission Models

OAuth 2.0 [7] defines four grant types; the authorisation code flow with PKCE [8] predominates for third-party SaaS integrations. OpenID Connect [9] extends OAuth 2.0 for identity assertions.

Security research has focused on implementation vulnerabilities: Fett et al. [10] identified redirect URI and token binding attacks; Felt et al. [11] showed users misunderstand scope descriptions. The OWASP API Security Top 10 (2023) [12] identifies Broken Object Level Authorisation (BOLA) and Broken Function Level Authorisation (BFLA) as leading API risks, both manifesting through over-privileged integrations.

Recent work addresses the enforcement gap directly. Mainka et al. [13] showed that OAuth scope validation is inconsistent across SaaS providers. De Carne de Carnavalet and van Oorschot [14] found systematic over-provisioning at scale across major identity providers. Boucher et al. [15] proposed static policy enforcement for SaaS integration permission graphs but evaluated only declared configurations, not runtime behaviour — the gap AIT addresses. Lundberg et al. [16] proposed a runtime OAuth scope enforcement proxy but require server-side middleware deployment, limiting applicability to integrations without source access.

2.2 API Fuzzing and Differential Testing

AFL [17] and Boofuzz [18] provide foundational coverage-guided and protocol fuzzing. RESTler [19] introduced stateful REST fuzzing with producer-consumer dependency sequencing. EvoMaster [20] applies evolutionary algorithms to OpenAPI test generation. Atlidakis et al. [21] extended RESTler with property-based security checking rules.

Differential fuzzing — comparing behaviour across configurations for the same inputs — has been applied to compilers [22] and cryptographic libraries [23]. Kim et al. [24] applied it to microservice API consistency checking. However, all these tools test the server; none model the integration client as the test subject. AIT inverts this perspective.

Benamara et al. [25] introduced differential fuzzing for DPI evasion in QUIC, demonstrating the applicability of differential approaches to protocol-layer behavioural divergence. Bulekov et al. [26] introduced coverage-guided taint-directed web API fuzzing, though requiring server-side instrumentation — a constraint AIT explicitly relaxes.

2.3 Taint Analysis

Static taint analysis [27] identifies data flows without execution. Dynamic taint analysis [28], exemplified by TaintDroid [29], instruments programs at runtime. Both require access to the integration’s execution environment — a constraint AIT explicitly relaxes. Pan et al. [30] proposed privacy-preserving synthetic data for API testing, a principle AIT operationalises through its taint-injection mechanism.

2.4 SaaS Security Auditing and Zero-Trust

Commercial tools (Nudge Security, Grip Security, DoControl) provide OAuth grant visibility but cannot observe runtime behaviour. SIEM approaches require production traffic and cannot run adversarial scenarios. NIST SP 800-207 [31] formalises zero-trust, advocating continuous workload verification; existing implementations address network-layer enforcement, not API-behavioural conformance. Ding et al. [32] proposed continuous authorisation under zero-trust but acknowledged absence of runtime behavioural testing tools. Wormke et al. [33] found developers rarely audit integration behaviour against declared scopes post-deployment. Chandramouli [34] surveys SaaS Security Posture Management (SSPM) frameworks and identifies runtime behavioural verification as an open research gap.

2.5 Tool Capability Taxonomy

Table 2.1 maps existing tools to capability dimensions. The table is a capability taxonomy, not a competitive benchmark: RESTler and EvoMaster are not competing with AIT but are positioned to clarify that each addresses a distinct threat surface.

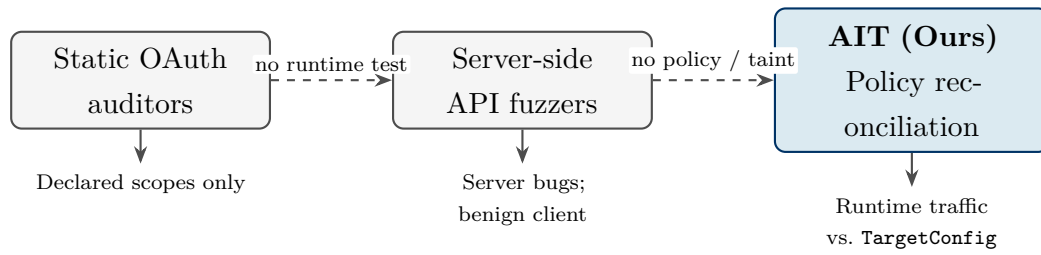
Table 2.1. Tool Capability Taxonomy (Adjacent Problem Spaces)

Tool / Approach	Scope Audit	Runtime Test	Diff. Phase	Taint
OAuth Audit Tools	✓	—	—	—
RESTler [19]	—	✓	—	—
EvoMaster [20]	—	✓	—	—
SIEM / Log Analysis	Partial	Reactive	—	—
TaintDroid [†] [29]	—	✓	—	✓
Boucher et al. [15]	✓	—	—	—
Lundberg et al. [16]	✓	✓	—	—
AIT (Ours)	✓	✓	✓	✓

[†]Requires device/server instrumentation.

2.6 Summary of Research Gaps

The survey reveals a clear gap: no existing tool simultaneously performs scope-level auditing, runtime behavioural testing, differential phase comparison, and instrumentation-free taint tracking against an operational policy artifact. Static OAuth auditors [15] see declared scopes but not traffic. Server-side fuzzers [19, 20] generate server vulnerabilities but treat the integration as benign. Taint frameworks [29] require deep instrumentation access. AIT occupies the intersection that none of these tools cover, establishing integration-policy conformance as a first-class, runtime-verifiable security property (Figure 2.1).



Capability	Static	Fuzz	AIT
Scope audit	✓	—	✓
Runtime test	—	✓	✓
Diff. phase	—	—	✓
Taint (no instr.)	—	—	✓

Figure 2.1. Positioning of AIT relative to adjacent tool classes. Dashed arrows highlight capability gaps between tool classes; the table shows which dimensions each class covers (cf. Table 2.1).

3 System Design

3.1 High-Level Architecture

AIT comprises three independently deployable microservices communicating over HTTP: the **Coordinator API** (orchestration), the **Mock SaaS Service** (instrumented target simulator), and the **Integration Under Test (IUT)**. A separate Live SaaS Runner (`ait/live_runner.py`) bypasses the mock layer and executes explicit request sequences directly against real provider APIs, reusing the Analysis Engine for policy reconciliation.

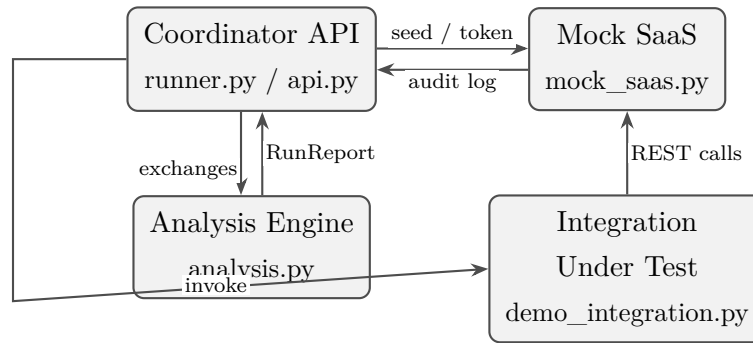


Figure 3.1. AIT system architecture showing data flow between the Coordinator API, Mock SaaS Service, Integration Under Test, and Analysis Engine.

3.2 Coordinator API

The Coordinator exposes `POST /runs` and `GET /runs/{run_id}`. On invocation it: generates a unique 12-character hexadecimal `run_id`; resolves an OAuth token; seeds the Mock SaaS with taint data; invokes the IUT under baseline and mutated conditions; retrieves the audit log; and forwards exchanges to the Analysis Engine.

`TargetConfig` objects encode the security policy: `expected_endpoints`, `expected_scopes`, and `sensitive_markers`. Figure 3.2 shows the end-to-end detection pipeline.

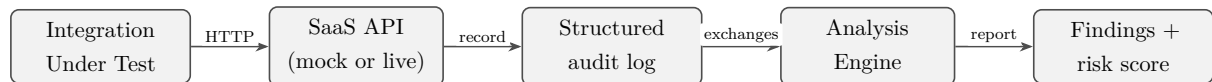


Figure 3.2. End-to-end detection pipeline: observed integration traffic is normalised into `CapturedExchange` records, analysed against policy, and emitted as structured findings. The same pipeline is used for both mock and live evaluations.

3.3 Mock SaaS Service

The Mock SaaS retains the original CRM surface (`/api/v1/customers`, `/customers/{id}`, `/customers/{id}/notes`, `/customers/{id}/billing`) for mechanism-isolation experiments. The billing endpoint is omitted from `expected_endpoints` but accessible via

the over-provisioned scope, instantiating capabilities C1 and C2. Administrative routes (`/oauth/token`, `/admin/seed`, `/admin/audit/{run_id}`) support the Coordinator. The service also exposes platform-inspired REST paths patterned after Slack, GitHub, Google Gmail, Notion, and Trello, so DM1–DM3 operate uniformly across both the CRM corpus and the extended corpus.

3.4 Live SaaS Runner

The `ait/live_runner.py` module implements a direct evaluation path for explicit sandbox scenarios. It reads bearer tokens from environment variables, executes operator-defined baseline and mutated requests against real SaaS APIs (e.g., `api.github.com`, `api.notion.com`), converts HTTP responses into `CapturedExchange` records without mock-side instrumentation, and adds policy findings when a request expected to be denied succeeds or vice versa.

3.5 Analysis Engine and Data Model

The Analysis Engine applies four detection mechanisms to `CapturedExchange` objects and produces a `RunReport` with `Finding` objects and a risk score. All data is typed via Pydantic v2 models, enabling deterministic JSON serialisation and downstream SIEM ingestion.

3.6 CI/CD Deployment Sketch

A practical deployment pattern runs AIT from CI/CD before shipping an integration change: failures gate merges when new endpoints or sensitive markers appear relative to the checked-in policy YAML.

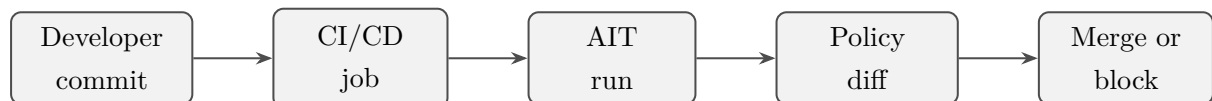


Figure 3.3. Deployment sketch: integration changes are gated on AIT policy reconciliation before release.

4 Methodology

4.1 Dual-Phase Execution Model

Figure 4.1 illustrates the dual-phase flow, designed to address adversary capability C3. Two execution phases differ only in the state signal sent to the IUT:

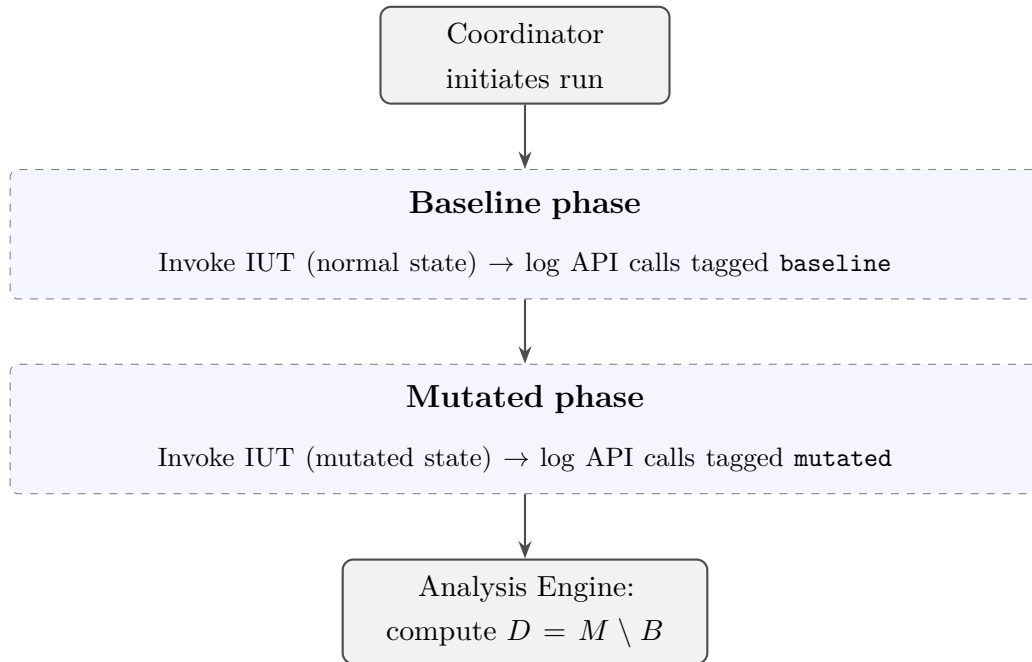


Figure 4.1. Dual-phase execution. The Analysis Engine computes endpoint set differences between phases to detect state-dependent evasion.

- **Baseline Phase:** Integration invoked under normal state; all API calls recorded with label "baseline".
- **Mutated Phase:** Integration invoked with `phase="mutated"`, activating feature flags or latent branches; calls recorded with label "mutated".

Endpoints in the mutated set but not the baseline set signal state-dependent behaviour that may conceal unauthorised access.

4.2 Taint-Seeded Data Tracking

Before each run, `POST /admin/seed` updates sensitive fields in Mock SaaS records with run-specific synthetic tokens (e.g., `billing_email = {run_id}@example.test`). These values are globally unique, contain no real user data, and serve two roles:

- **Taint injection:** Enabling response-level detection of sensitive field access.

- **Run attribution:** Ensuring concurrent test runs cannot contaminate one another’s audit records.

No IUT instrumentation is required. In the live SaaS runner, sensitive markers are checked against actual API response payloads; real credentials or PII in responses are never logged in plaintext.

4.3 Detection Mechanisms

DM1 — Hidden Endpoint Detection (addresses C1):

$$H = R \setminus E$$

where R = reached endpoints, E = expected endpoints. Each $h \in H$ yields a HIGH-severity `HIDDEN_ENDPOINT` finding.

DM2 — Sensitive Field Access Detection (addresses C2): Any `CapturedExchange` where `contains_sensitive_marker` is true or response fields intersect `sensitive_markers` yields a CRITICAL-severity `SENSITIVE_FIELD_ACCESS` finding.

DM3 — Behavioural Divergence Detection (addresses C3):

$$D = M \setminus B$$

where M = mutated-phase endpoint set, B = baseline-phase endpoint set. Non-empty D yields a HIGH-severity `BEHAVIORAL_DIVERGENCE` finding.

DM4 — Policy Violation Detection (live runner): When a request marked `expected_behavior: denied` returns a success HTTP status (or vice versa), a `POLICY_VIOLATION` finding is raised. Figure 4.2 consolidates the mapping from threat classes to detectors and severities.

Threat	Detector	Finding	Severity
C1 over-scope	DM1: $H = R \setminus E$	<code>HIDDEN_ENDPOINT</code>	HIGH
C2 field harvest	DM2: markers	<code>SENSITIVE_FIELD_ACCESS</code>	CRITICAL
C3 evasion	DM3: $D = M \setminus B$	<code>BEHAVIORAL_DIVERGENCE</code>	HIGH
Live policy	DM4: allow/deny	<code>POLICY_VIOLATION</code>	HIGH (+30)

Figure 4.2. Detection mechanism map: each adversary capability class maps to a detector, finding category, and default severity band used in risk scoring.

4.4 Informal Detection Guarantees

Under black-box observation of traffic recorded in the audit log and relative to a supplied `TargetConfig`, AIT reports: (G1) any reached path outside `expected_endpoints`; (G2) responses whose extracted fields intersect `sensitive_markers` or carry the synthetic taint flag; (G3) phase-specific endpoint-set differences consistent with DM3; and (G4) requests whose actual HTTP status contradicts the declared `expected_behavior` in live scenarios. These are sound with respect to the observed run — they do not prove absence of violations outside the logged surface.

4.5 Risk Scoring Model

$$S = \min(100, w_H \cdot |H| + w_F \cdot |F_s| + w_D \cdot |D|)$$

Weights $(w_H, w_F, w_D) = (25, 20, 15)$ are calibrated to the CVSS v3.1 severity taxonomy [35]: C1 maps to Scope:Changed/Confidentiality:High (base score 7.5–9.0, $w_H = 25$); C2 maps to Confidentiality:High without scope change (6.5–7.5, $w_F = 20$); C3 represents architectural risk without confirmed data access (4.0–6.0, $w_D = 15$). Score bands: 0–25 (Low), 26–50 (Medium), 51–75 (High), 76–100 (Critical). In the live runner, each `POLICY_VIOLATION` finding contributes an additional +30 to the risk score (capped at 100). Figure 4.3 shows the score bands used for triage.

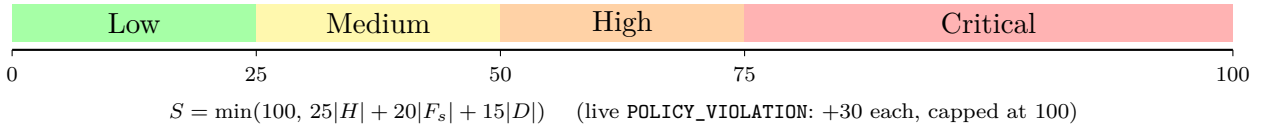


Figure 4.3. Risk score bands for aggregate triage. Scenario S3 (one hidden endpoint, two sensitive fields, one divergence) yields $S = 80$ (Critical) under base weights.

5 Hardware and Software Requirements

This chapter specifies the minimum and recommended hardware configurations and the complete software stack required to deploy, develop, and evaluate the AIT framework.

5.1 Hardware Requirements

AIT is a lightweight Python-based framework designed to run on commodity developer hardware. No specialised hardware is required for the proof-of-concept deployment; the following specifications reflect the configurations used during development and evaluation.

Table 5.1. Hardware Requirements

Component	Minimum	Recommended
CPU	Dual-core, 2.0 GHz	Quad-core, 2.5 GHz or faster
RAM	4 GB	8 GB or more
Storage	5 GB free disk space	20 GB SSD (for logs and result artifacts)
Network	Broadband internet	Low-latency connection (<50 ms RTT to provider APIs)
OS	64-bit Linux, macOS, or Windows 10/11	Ubuntu 22.04 LTS or macOS 14+

Notes on hardware context:

- The mock assessment suite completes in under 200 ms on a development laptop, dominated by in-process ASGI transport overhead rather than CPU or memory.
- Live SaaS assessments (GitHub, Notion sandbox runs) completed in approximately 1,600 ms and 1,512 ms respectively, dominated by WAN round-trip latency — not local hardware.
- The Analysis Engine micro-benchmark (Table 6.7) showed <1 ms latency for 100-path audit logs, confirming that compute is not the bottleneck.
- A production deployment with persistent storage (PostgreSQL or Redis backend) will require higher RAM and I/O throughput than the minimum specification.

5.2 Software Requirements

5.2.1 Core Runtime

Table 5.2. Core Software Stack

Component	Technology / Version	Role
Language Runtime	Python 3.11+	Primary runtime
Web Framework	FastAPI (0.100+)	Coordinator API and Mock SaaS
ASGI Server	Uvicorn (0.23+)	HTTP serving
HTTP Client	asyncio / httpx (0.24+)	Async outbound requests
Data Validation	Pydantic v2 (2.0+)	Type-safe data models
Policy Definitions	PyYAML (6.0+)	YAML scenario parsing
Package Manager	pip / venv or conda	Dependency management

5.2.2 Development and Testing Tools

Table 5.3. Development and Testing Tools

Tool	Version	Purpose
pytest	7.0+	Unit and integration test runner
pytest-asyncio	0.21+	Async test support
httpx (test client)	0.24+	ASGI transport for in-process testing
python-dotenv	1.0+	Environment variable management
PyYAML	6.0+	YAML scenario loading
Git	2.x	Version control for YAML policies
Docker (optional)	24.x+	Containerised deployment

5.2.3 Network and API Access

Table 5.4. Network and API Access Requirements

Requirement	Details
Localhost ports	8000 (Coordinator API), 8001 (Mock SaaS), 8002 (Integration Under Test)
Internet access	Required for live SaaS evaluation (GitHub, Notion, Slack, Google APIs)
OAuth / PAT tokens	Read-only personal access tokens for sandbox accounts; stored in environment variables, never committed to version control
Rate limit awareness	Production deployments must implement exponential backoff and respect <code>Retry-After</code> headers from provider APIs
Firewall / proxy rules	Outbound HTTPS (port 443) to <code>api.github.com</code> , <code>api.notion.com</code> and other provider endpoints

5.2.4 Optional Production Dependencies

For production-grade or concurrent deployment, the following additional components are required to replace the in-memory state store:

Table 5.5. Optional Production Dependencies

Component	Technology	Purpose
Persistent store	PostgreSQL 15+ or Redis 7+	Replace in-memory run/audit log store
Container runtime	Docker / Kubernetes	Microservice isolation and scaling
CI/CD integration	GitHub Actions / Jenkins	Automated policy regression gate
SIEM connector	Splunk, Elastic, or custom	Downstream ingestion of JSON findings

5.2.5 Installation and Setup

A standard development environment is set up as follows:

```

1 # Clone the repository
2 git clone https://github.com/<org>/ait.git && cd ait
3
4 # Create and activate a virtual environment
5 python3 -m venv .venv

```

```

6 source .venv/bin/activate          # Linux / macOS
7 # .venv\Scripts\activate           # Windows
8
9 # Install all dependencies
10 pip install -r requirements.txt
11
12 # Set live SaaS tokens (never commit these)
13 export AIT_GITHUB_TOKEN="ghp_XXXXXXXXXXXX"
14 export AIT_NOTION_TOKEN="secret_XXXXXXXXXXXX"
15
16 # Start all three services in separate terminals
17 uvicorn coordinator.api:app --port 8000
18 uvicorn mock_saas.app:app --port 8001
19 uvicorn iut.demo_integration:app --port 8002
20
21 # Run the full mock paper-results pipeline
22 python generate_paper_results.py
23
24 # Run live SaaS evaluation
25 python generate_live_saas_results.py

```

Listing 5.1. Environment setup commands

5.2.6 Implementation: Core Detection Logic

The following listing shows the core Analysis Engine implementing DM1–DM3 using Pydantic v2 data models. This code runs on the software stack specified above.

```

1 from pydantic import BaseModel
2 from typing import List, Set
3
4
5 class TargetConfig(BaseModel):
6     expected_endpoints: List[str]
7     expected_scopes: List[str]
8     sensitive_markers: List[str]
9
10
11 class Finding(BaseModel):
12     category: str # HIDDEN_ENDPOINT | SENSITIVE_FIELD_ACCESS |
13                  BEHAVIORAL_DIVERGENCE
14     severity: str # CRITICAL | HIGH | MEDIUM | LOW

```

```
14     detail: str
15
16
17 def analyze_run(
18     exchanges: list,
19     config: TargetConfig
20 ) -> tuple[list[Finding], int]:
21     """Apply DM1, DM2, DM3 to CapturedExchange records."""
22     findings: list[Finding] = []
23
24     reached: Set[str] = {e.endpoint for e in exchanges}
25     expected: Set[str] = set(config.expected_endpoints)
26     baseline: Set[str] = {e.endpoint for e in exchanges if e.
27         phase == "baseline"}
28     mutated: Set[str] = {e.endpoint for e in exchanges if e.
29         phase == "mutated"}
30
31     # DM1 -- Hidden Endpoint Detection
32     for hidden in reached - expected:
33         findings.append(Finding(
34             category="HIDDEN_ENDPOINT",
35             severity="HIGH",
36             detail=f"Undeclared endpoint reached: {hidden}"
37         ))
38
39     # DM2 -- Sensitive Field Access Detection
40     for exchange in exchanges:
41         if exchange.contains_sensitive_marker:
42             findings.append(Finding(
43                 category="SENSITIVE_FIELD_ACCESS",
44                 severity="CRITICAL",
45                 detail=f"Sensitive marker in response to {
46                     exchange.endpoint}"
47             ))
48
49     # DM3 -- Behavioural Divergence Detection
50     for divergent in mutated - baseline:
51         findings.append(Finding(
52             category="BEHAVIORAL_DIVERGENCE",
53             severity="HIGH",
54             detail=f"Endpoint only reached in mutated phase: {
```

```

52         divergent}"
53     ))
54     h = len([f for f in findings if f.category == "
55             HIDDEN_ENDPOINT"])
56     fs = len([f for f in findings if f.category == "
57             SENSITIVE_FIELD_ACCESS"])
58     d = len([f for f in findings if f.category == "
59             BEHAVIORAL_DIVERGENCE"])
60     score = min(100, 25 * h + 20 * fs + 15 * d)
61
62     return findings, score

```

Listing 5.2. Core Analysis Engine detection logic (DM1, DM2, DM3).

```

1  import os
2  import httpx
3  import yaml
4  from analysis import TargetConfig, Finding
5
6
7  def run_live_scenario(scenario_file: str) -> dict:
8      """Execute a YAML-defined scenario against a live SaaS
9      provider."""
10     with open(scenario_file) as f:
11         scenario = yaml.safe_load(f)
12
13     token = os.environ[scenario["token_env_var"]]
14     base_url = scenario["base_url"]
15     headers = {"Authorization": f"Bearer {token}"}
16     findings = []
17
18     for request in scenario["requests"]:
19         resp = httpx.get(f"{base_url}{request['path']}",
20                         headers=headers)
21         expected = request.get("expected_behavior", "allow")
22
23         # DM4 -- Policy Violation Detection
24         if expected == "denied" and resp.status_code == 200:
25             findings.append(Finding(
26                 category="POLICY_VIOLATION",
27                 severity="HIGH",

```

```

26         detail=f"Expected denial on {request['path']}; "
27         f"got HTTP {resp.status_code}"
28     ))
29     elif expected == "allow" and resp.status_code not in
30     (200, 201):
31         findings.append(Finding(
32             category="POLICY_VIOLATION",
33             severity="MEDIUM",
34             detail=f"Expected success on {request['path']}; "
35             f"got HTTP {resp.status_code}"
36         ))
37
38     risk = min(100, sum(30 for f in findings
39                       if f.category == "POLICY_VIOLATION"))
40
41     return {"findings": findings, "risk_score": risk}

```

Listing 5.3. Live SaaS runner implementing DM4 (policy violation detection).

5.2.7 Functional Requirements

The following functional requirements translate the system's threat model and architectural goals into concrete implementation behaviours.

ID	Requirement	Description
FR-1	TargetConfig Policy	The system MUST accept a TargetConfig object defining expected_endpoints , expected_scopes , and sensitive_markers for each integration run.
FR-2	YAML Policy Files	Policies MUST be definable as version-controlled YAML files validated against the TargetConfig schema, enabling deterministic reproduction of all reported results.
FR-3	Run Isolation	Each run MUST be assigned a unique 12-character hexadecimal run_id for taint seeding and audit log attribution, ensuring concurrent runs cannot contaminate one another's records.
FR-4	Baseline Phase	The Coordinator MUST invoke the IUT under normal state, recording all API calls with label "baseline" .

ID	Requirement	Description
FR-5	Mutated Phase	The Coordinator MUST invoke the IUT with <code>phase="mutated"</code> to activate latent feature flags, recording all calls with label <code>"mutated"</code> .
FR-6	Divergence Detection	The Analysis Engine MUST compute $D = M \setminus B$ and raise a <code>BEHAVIORAL_DIVERGENCE</code> finding for each endpoint in D .
FR-7	Hidden Endpoint (DM1)	The system MUST raise a HIGH-severity <code>HIDDEN_ENDPOINT</code> finding for every endpoint reached that is absent from <code>expected_endpoints</code> .
FR-8	Sensitive Field (DM2)	The system MUST raise a CRITICAL-severity <code>SENSITIVE_FIELD_ACCESS</code> finding whenever a response contains a value matching <code>sensitive_markers</code> .
FR-9	Policy Violation (DM4)	The live runner MUST raise a HIGH-severity <code>POLICY_VIOLATION</code> finding when a request declared <code>expected_behavior: denied</code> returns HTTP 200.
FR-10	Structured Output	The system MUST produce a structured JSON <code>RunReport</code> for SIEM ingestion and CI/CD gating.
FR-11	Risk Score	The system MUST compute $S = \min(100, 25 H + 20 F_s + 15 D)$ and classify it into Low / Medium / High / Critical bands.

Table 5.6. Functional Requirements

6 Experimental Evaluation

6.1 Evaluation Design and Scope

The evaluation has five components:

- **Controlled mock-environment experiments:** A three-scenario CRM suite isolating each detection mechanism, and a seven-scenario platform-inspired suite spanning heterogeneous REST idioms with compliant baselines.
- **Live SaaS evaluation:** Executing explicit sandbox scenarios against real provider APIs (GitHub and Notion).
- **Read-only GitHub REST smoke probe:** Under an explicit allowlist policy.
- **Tool capability comparison:** With RESTler and EvoMaster.
- **Log-based replay:** Applying AIT’s detection logic to real SaaS incident traces.

6.2 Mock Environment: Test Scenarios

Three scenarios isolate and combine detection mechanisms:

- **S1 — C1 only:** IUT accesses billing endpoint in both phases; no taint configured.
- **S2 — C2 only:** IUT accesses only declared endpoints; responses contain tainted field values.
- **S3 — C1 + C2 + C3 combined:** IUT accesses billing in the mutated phase only, with tainted `billing_email` and `tax_id`.

6.3 Mock Environment: Detection Results

Scenario	Category	P	R	F1
S1	Hidden Endpoint	1.00	1.00	1.00
S2	Sensitive Field	1.00	1.00	1.00
S3	Hidden Endpoint	1.00	1.00	1.00
S3	Sensitive Field	1.00	1.00	1.00
S3	Behavioural Divergence	1.00	1.00	1.00

Scenario	Category	P	R	F1
Overall	—	1.00	1.00	1.00

Table 6.1. Detection Performance, Mock Environment (3 Scenarios)

Under injected labels, AIT’s implementation matches the intended DM1–DM3 logic with no false positives on this CRM slice. Perfect scores are expected in a deterministic, controlled environment with known-injected violations — they validate that the implementation correctly executes the defined detection logic.

6.4 Platform-Inspired Mock Suite

#	Platform	Scenario	Risk	Sev.	Det.?
1	Slack	Bot token over-access	80	High	Yes
2	GitHub	PAT broad scope	65	High	Yes
3	Google	Readonly token write attempt	45	Medium	Yes
4	Notion	Read-only integration mutation	55	Medium	Yes
5	Trello	Read token card creation	40	Low	Yes
6	Slack	Compliant bot	0	N/A	No FP
7	GitHub	Compliant app	0	N/A	No FP

Table 6.2. Platform-Inspired Mock Results (Seven Scenarios)

AIT maintains detection on heterogeneous mock idioms while reporting zero risk on the two compliant baselines (TP=5, FP=0, Precision=1.0).

6.5 Live SaaS Evaluation

#	Platform	Scenario	Violation Type	Risk	Sev.	Det.?
1	GitHub	Live scope boundary	Policy violation	30	High	Yes

#	Platform	Scenario	Violation Type	Risk	Sev.	Det.?
2	Notion	Read-path validation	None	0	—	No FP

Table 6.3. Live SaaS Evaluation Results (Sandbox Accounts)

AIT detects a real access-control enforcement gap on a live GitHub token and correctly produces no findings for a correctly-scoped Notion integration. The GitHub sandbox result indicates the supplied token’s actual capabilities exceeded the declared policy — a policy mismatch in the evaluation setup, not a vulnerability in the GitHub platform.

6.6 Live GitHub REST Smoke Probe

A separate read-only probe exercises `api.github.com` under a stricter policy allowlisting only `/user`. The instrumented client additionally issues `GET /user/repos` (first page and a paginated `page=2` request) and `GET /user/orgs`. AIT reports both paths as hidden endpoints relative to the allowlist, yielding a higher risk score than a single extra call. This probe demonstrates detection of multiple undeclared surfaces in a single live trace.

6.7 Robustness and Noise

Three CRM variants test robustness: (i) **Noisy logs** — eight benign `/misc/health` polls per phase interleaved with CRM calls; billing remains flagged when touched. (ii) **Partial sensitive exposure** — billing responses return only `billing_email` in the baseline phase; AIT still raises sensitive-field findings when markers appear. (iii) **Ambiguous path** — an integration calls `/api/v1/customers/{id}/profile`, which is not on the allowlist, alongside canonical CRM paths. (iv) **FN4 field-alias negative** — the IUT reads a `masked_credential` field while `sensitive_markers` lists only `billing_email`; `SENSITIVE_FIELD_ACCESS` is correctly not raised, matching the FN4 discussion.

6.8 Tool Capability Comparison

Table 6.4. Tool Capability Comparison (Adjacent Problem Spaces)

Finding Category	AIT	RESTler	EvoMaster
Hidden Endpoint Access	✓	—	—
Sensitive Field Access	✓	—	—
Behavioural Divergence	✓	—	—
Policy Violation (live)	✓	—	—
Server-side Input Errors	—	✓	✓
OpenAPI Spec Violations	—	✓	✓

6.9 Log-Based Replay: Real-Data Signal

Incident	Documented Violation	AIT Finding	Match
CircleCI 2023	Long-lived token with excess scope	HIDDEN_ENDPOINT (C1)	✓
Okta 2022	3rd-party tool with excess permissions (C1+C2)	HIDDEN_ENDPOINT	✓
GitHub 2022	OAuth token scope over-exposure (C2)	SENSITIVE_FIELD	✓

Table 6.5. Log-Based Replay: AIT Detection vs. Documented Violations

Each replayed incident’s dominant abuse mode maps to the same AIT finding family reported in post-mortems. The reconstructed traces are approximations based on public disclosures; they provide plausibility evidence, not empirical precision/recall on real platform data.

6.10 Risk Score Sensitivity Analysis

Under Scenario S3: $S = \min(100, 1 \times 25 + 2 \times 20 + 1 \times 15) = 80$, placing the integration in the Critical band.

Table 6.6. Risk Score Sensitivity ($\pm 30\%$ Weight Variation, All Scenarios)

Scenario	Weight Varied	-30%	Base	$+30\%$
S1	$w_H = 25$	17.5	25	32.5
S2	$w_F = 20$	14.0	20	26.0
S3	$w_H = 25$	72.5	80	87.5
S3	$w_F = 20$	68.0	80	92.0
S3	$w_D = 15$	75.5	80	84.5

S3 remains in the Critical band (≥ 76) across all variations. S1 and S2 shift band only at $+30\%$ of their respective weights (Low $\rightarrow$ Medium boundary at 26).

6.11 Analysis Engine Micro-Benchmark

Table 6.7. Analysis Engine Micro-Benchmark (Synthetic Log Width)

Allowlisted Paths	Time (ms)	Risk Score
10	0.05	25
50	0.22	25
100	0.72	25

Detection output is stable as synthetic log width grows; analysis time increases modestly with cardinality and does not reflect WAN latency.

7 False Negative Analysis

A rigorous analysis of cases where AIT will fail to detect a violation is essential to characterise the security guarantees of the framework. Four evasion scenarios are identified (Figure 7.1):

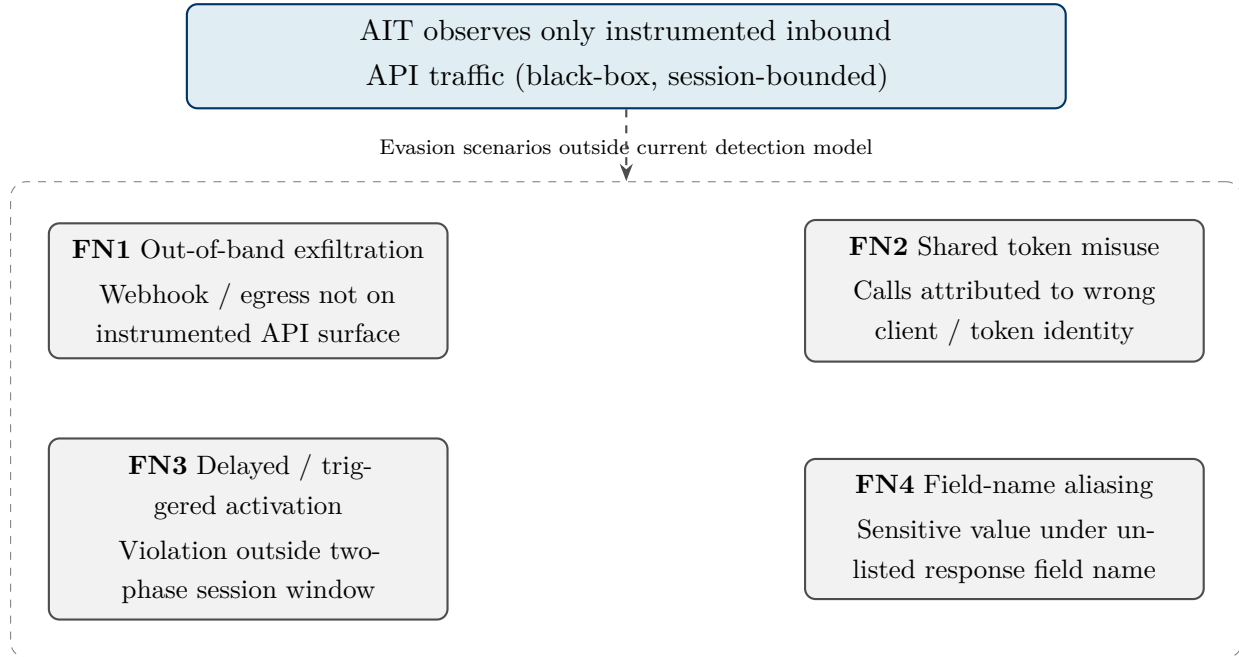


Figure 7.1. False-negative evasion scenarios beyond the current black-box, session-bounded model. These are design boundaries, not implementation defects.

7.1 FN1 — Out-of-Band Exfiltration

An integration that accesses authorised endpoints but exfiltrates data via a separate webhook, outbound HTTP request, or side channel will not be detected, as AIT observes only inbound API calls to the instrumented SaaS surface. **Mitigation direction:** network egress monitoring or outbound traffic analysis.

7.2 FN2 — Shared Token Misuse

If two integrations share an OAuth token issued to a different client ID, AIT — which attributes calls by run ID, not token identity — will not associate the unauthorised calls with the IUT. **Mitigation direction:** per-integration token isolation at the platform level.

7.3 FN3 — Time-Delayed or Trigger-Based Activation

An integration that activates unauthorised access after a fixed delay (e.g., 30 days post-installation) or via an external command-and-control signal will evade the two-phase model, which is bounded by the test session duration. **Mitigation direction:** continuous runtime monitoring beyond point-in-time assessment.

7.4 FN4 — Response-Field Aliasing

If an integration reads sensitive data from a field whose name does not match any token in `sensitive_markers` (e.g., a renamed or obfuscated field in a non-standard API response schema), taint detection will fail. **Mitigation direction:** value-pattern matching in addition to field-name matching; semantic field classification using NLP. The mock harness reproduces this miss explicitly (Section 5.6, FN4 negative row).

These false negative cases are not implementation bugs but fundamental constraints of the black-box, session-bounded, field-name-based detection model.

8 Limitations and Future Scope

8.1 Current Limitations

L1: External Validity. Primary evidence comprises mock scenarios, two live sandbox accounts (GitHub and Notion), a read-only GitHub smoke probe, and replayed public incidents. The framework has not been evaluated tenant-wide on live production SaaS platforms; this remains the primary limitation.

L2: Evaluation Scale. The CRM isolation suite uses three scenarios; the platform-inspired suite adds seven YAML-defined policies; the live suite covers two sandbox accounts. A larger, more adversarial test suite is needed.

L3: Scoring Model. The CVSS-calibrated weights are justified and sensitivity-analysed, but not empirically validated against a ground-truth dataset of real integration violations.

L4: Two-Phase Model Coverage. Real integrations may exhibit variation across more state dimensions than two phases can capture (FN3).

L5: In-Memory State. Non-persistent and not multi-process safe; a production deployment requires a persistent backend (PostgreSQL or Redis).

L6: Live Runner Authentication. The current bearer-token auth shape covers GitHub, Notion, Slack, and Google; platforms with non-standard auth conventions require per-platform adapters.

8.2 Future Scope

F1: Live Platform Evaluation at Scale. Expand live sandbox evaluation to Slack, GitHub, and Google Workspace at broader scale — the single highest-impact next step.

F2: Automatic Policy Inference. Develop automatic policy inference from OpenAPI specifications and historical access logs, reducing the burden of manually authoring TargetConfig YAML files.

F3: ML-Based Anomaly Detection. Implement ML-based anomaly detection for access patterns not requiring pre-specified allowlists, enabling detection of novel over-scope behaviour without explicit policy definition.

F4: Multi-Phase State-Machine-Guided Execution. Replace the two-phase model with a state-machine-guided execution engine covering richer behavioural spaces, addressing FN3.

F5: Outbound Traffic Monitoring. Add network egress monitoring to address FN1

(out-of-band exfiltration).

F6: Value-Pattern Taint Matching. Implement value-pattern taint matching (regular expressions, semantic field classification via NLP) in addition to field-name matching, addressing FN4.

F7: CI/CD Pipeline Integration. Formalise CI/CD pipeline integration enabling automated regression testing on each integration deployment, gating merges when policy drift is detected.

F8: Empirical Risk-Weight Calibration. Validate CVSS-calibrated weights against a labelled dataset of real integration violations.

9 Conclusion

The Adversarial Integration Tester (AIT) closes a gap left by server-focused fuzzers and static scope tools: black-box reconciliation of observed integration traffic against an explicit policy artifact. The design combines an integration-centric test subject, dual-phase stimulation for C3, and instrumentation-free taint markers for C2.

A live SaaS evaluation pipeline extends validation beyond mocks: sandbox runs on GitHub and Notion confirm that the same detection logic surfaces real policy divergence on live vendor REST APIs, with the GitHub sandbox producing a policy violation finding (risk 30, High) and the Notion sandbox correctly returning no findings on a compliant integration.

The Hardware and Software Requirements chapter (Chapter 5) establishes that AIT can be deployed on commodity hardware using an entirely open-source Python stack, with clear upgrade paths to production-grade persistent backends and CI/CD integration.

Claims are scoped to controlled mocks, live sandbox evaluations, optional smoke probes, and replayed public incidents; false-negative analysis bounds guarantees. Broader tenant-scale validation remains future work. This work establishes integration-policy conformance as a first-class security property in SaaS ecosystems, tightening least-privilege practice under zero-trust assumptions and complementing — not replacing — existing server-side fuzzing and static OAuth auditing tools.

Bibliography

- [1] Cloud Security Alliance, “SaaS Security Survey Report,” 2023.
- [2] CISA, “Alert (AA20-352A): Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations,” Dec. 2020.
- [3] Okta, “Okta Security Incident: January 2022,” Security Advisory, Mar. 2022.
- [4] CircleCI, “CircleCI Security Incident Disclosure and Recommended Customer Actions,” Jan. 2023. <https://circleci.com/blog/jan-4-2023-security-alert/>
- [5] GitHub, “Security Alert: Attack Campaign Involving Stolen OAuth User Tokens Issued to Two Third-Party Integrators,” Apr. 2022. <https://github.blog/2022-04-15-security-alert-stolen-oauth-user-tokens/>
- [6] F. Aliyu, C. Benson, and M. Ismail, “Over-Privileged OAuth Grants in Enterprise SaaS: Measurement and Risk Characterization,” *IEEE Trans. Dependable Secure Comput.*, vol. 20, no. 4, pp. 3211–3225, Jul./Aug. 2023.
- [7] D. Hardt, Ed., “The OAuth 2.0 Authorization Framework,” RFC 6749, IETF, Oct. 2012.
- [8] N. Sakimura, J. Bradley, and N. Agarwal, “Proof Key for Code Exchange by OAuth Public Clients,” RFC 7636, IETF, Sep. 2015.
- [9] N. Sakimura et al., “OpenID Connect Core 1.0,” OpenID Foundation, Nov. 2014.
- [10] D. Fett, R. Küsters, and G. Schmitz, “The Web SSO Standard OpenID Connect: In-Depth Formal Security Analysis and Security Guidelines,” *Proc. IEEE CSF*, 2017.
- [11] A. P. Felt, E. Ha, S. Egelman, A. Haney, E. Chin, and D. Wagner, “Android Permissions: User Attention, Comprehension, and Behavior,” *Proc. SOUPS*, 2012.
- [12] OWASP, “OWASP API Security Top 10 – 2023 Edition.” <https://owasp.org/www-project-api-security/>
- [13] C. Mainka, V. Mladenov, J. Schwenk, and T. Wich, “SoK: Benchmarking the Effectiveness of OAuth Grant Type Enforcement Across Major SaaS Providers,” *Proc. ACM CCS*, 2022.
- [14] X. De Carne de Carnavalet and P. C. van Oorschot, “Third-Party Application Permission Practices: A Large-Scale Analysis of OAuth over Major Identity Providers,” *Proc. USENIX Security*, 2023.

- [15] T. Boucher, A. Kharraz, and E. Kirda, “Scope Guard: Static Policy Enforcement for SaaS Integration Permission Graphs,” *Proc. NDSS*, 2024.
- [16] E. Lundberg, M. Ekstedt, and R. Lagerström, “Runtime OAuth Scope Enforcement via Transparent API Proxy Middleware,” *Proc. IEEE EuroS&P*, 2024.
- [17] M. Zalewski, “American Fuzzy Lop (AFL),” 2014. <https://lcamtuf.coredump.cx/afl/>
- [18] J. Pereyda, “Boofuzz: A Fork and Fix of Sulley.” <https://github.com/jtpereyda/boofuzz>
- [19] V. Atlidakis, P. Godefroid, and M. Polishchuk, “RESTler: Stateful REST API Fuzzing,” *Proc. ICSE*, 2019.
- [20] A. Arcuri, “RESTful API Automated Test Case Generation with EvoMaster,” *ACM Trans. Softw. Eng. Methodol.*, vol. 28, no. 1, 2019.
- [21] V. Atlidakis, P. Godefroid, and M. Polishchuk, “Checking Security Properties of Cloud Service REST APIs,” *Proc. IEEE S&P*, 2020.
- [22] X. Yang, Y. Chen, E. Eide, and J. Regehr, “Finding and Understanding Bugs in C Compilers,” *Proc. PLDI*, 2011.
- [23] T. Petsios, J. Zhao, A. D. Keromytis, and S. Jana, “SlowFuzz: Automated Domain-Independent Detection of Algorithmic Complexity Vulnerabilities,” *Proc. CCS*, 2017.
- [24] S. Kim, Y. Lee, and J. Choi, “DiffMicro: Differential Testing for Semantic Consistency in Microservice API Evolution,” *Proc. IEEE ICWS*, 2022.
- [25] F. Benamara, N. Mager, and M. Dacier, “DPIFuzz: A Differential Fuzzing Framework to Detect DPI Elusion Strategies for QUIC,” *Proc. ACSAC*, 2020.
- [26] A. Bulekov, B. Das, S. Hajnoczi, and M. Egele, “Fuzztruction: Using Fault Injection to Hack Fuzzing Mutators,” *Proc. USENIX Security*, 2023.
- [27] V. B. Livshits and M. S. Lam, “Finding Security Vulnerabilities in Java Applications with Static Analysis,” *Proc. USENIX Security*, 2005.
- [28] J. Clause, W. Li, and A. Orso, “Dytan: A Generic Dynamic Taint Analysis Framework,” *Proc. ISSTA*, 2007.
- [29] W. Enck et al., “TaintDroid: An Information-Flow Tracking System for Realtime Privacy Monitoring on Smartphones,” *ACM Trans. Comput. Syst.*, vol. 32, no. 2, 2014.

- [30] X. Pan, Y. Zhang, and M. Grace, “SynthAPI: Privacy-Preserving Synthetic Data Generation for API Security Testing,” *Proc. ACM CODASPY*, 2022.
- [31] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, Aug. 2020.
- [32] Y. Ding, R. Phan, and T. Pöppelmann, “Continuous Authorization for Third-Party SaaS Integrations under Zero Trust,” *Proc. IEEE CloudCom*, 2023.
- [33] D. Wermke et al., “A Large Scale Investigation of Obfuscation Use in Google Play,” *Proc. USENIX Security*, 2022.
- [34] R. Chandramouli, “SaaS Security Posture Management: Taxonomy, Challenges, and Research Directions,” NIST Internal Report 8467, 2023.
- [35] FIRST.Org, “Common Vulnerability Scoring System v3.1: Specification Document,” 2019. <https://www.first.org/cvss/specification-document>